

Narrativa explicativa para el despliegue de la Encuesta OCTAVE Nacional

Texto base para invitar a las organizaciones a participar, contextualizar los objetivos y preparar el terreno para conversaciones serias sobre riesgos... sin perder del todo el sentido del humor.

1. Carta de invitación a las organizaciones

Estimado/a responsable de ciberseguridad, riesgos o, sencillamente, de que **todo siga funcionando cuando algo haga “clic” donde no debe**:

Vivimos un momento en el que los titulares sobre ciberataques compiten alegremente con las noticias de economía, política y deporte. Ransomware, fugas de datos, interrupciones de servicios esenciales... Si su organización no ha sido todavía protagonista, enhorabuena; si ya lo ha sido, lo lamentamos y esperamos que haya aprendido algo más útil que una nueva contraseña.

En este contexto, hemos diseñado la **Encuesta OCTAVE Nacional**, un instrumento que persigue tres fines muy concretos:

- Comprender cómo gestionan realmente las organizaciones españolas los riesgos de ciberseguridad.
- Medir un Índice Global de Madurez (IGM) comparable entre sectores y a lo largo del tiempo.
- Disponer de material serio —y no solo escalofriantes casos de estudio— para hablar de inversión, retorno y prioridades en ciberseguridad con la alta dirección.

No buscamos héroes ni historias épicas de todo bajo control. Buscamos **honestidad**, porque solo a partir de un diagnóstico sincero puede trazarse un plan de mejora que vaya más allá del powerpoint inspirador.

2. Qué mide la encuesta (y qué no)

La encuesta aborda, entre otros, los siguientes ámbitos:

- La gobernanza de la ciberseguridad: quién decide, con qué información y cada cuánto.
- La forma en que se identifican y protegen los activos críticos (no solo servidores, también procesos, datos y proveedores).
- Cómo se definen y aplican los criterios de impacto y probabilidad, al estilo OCTAVE Allegro/FORTE.
- La realidad de la gestión de vulnerabilidades, incidentes y continuidad de negocio.
- El nivel de alineamiento con ENS, NIS2, ISO 27001, NIST CSF y otros marcos.
- La existencia (o ausencia) de métricas, cuadros de mando e intentos de calcular ROI/ROSI de la ciberseguridad.

La encuesta **no pretende**:

- Sustituir auditorías técnicas, pentests ni análisis detallados de riesgos.
- Emitir sentencias morales sobre organizaciones “buenas” o “malas”.
- Convertirse en un ranking público de vergüenza ajena.

Sí pretende, en cambio, ser una **brújula compartida**: un instrumento para que cada organización entienda dónde está, hacia dónde podría ir y qué compañías tiene en el camino.

3. Por qué este enfoque: OCTAVE, ENS, NIS2 y compañía

El cuestionario se apoya en varios pilares:

- La familia de métodos OCTAVE (clásico, Allegro, FORTE), que insiste en empezar por los activos críticos, las amenazas y las vulnerabilidades y en traducir todo ello a riesgos gestionables, con criterios de impacto claros.
- El Esquema Nacional de Seguridad (ENS) y el Real Decreto 311/2022, que obligan a una gestión basada en riesgos, a la vigilancia continua y a la auditoría periódica.
- La Directiva NIS2 y su desarrollo, que extienden obligaciones a un mayor número de sectores y refuerzan la exigencia de gestión de riesgos y notificación.
- Los marcos internacionales (ISO 27001/27005, NIST CSF) y la agenda de medición de ciberseguridad impulsada por ENISA, la OCDE y la UIT, que alimentan indicadores sobre capacidad nacional, madurez y resultados.

En suma, el cuestionario no es un invento caprichoso: es un intento de **poner orden en el cruce de marcos, normas e índices**, traduciendo todo ello a preguntas comprensibles para quienes, día a día, sostienen la seguridad digital de sus organizaciones.

4. Qué obtiene su organización a cambio

Participar en la Encuesta OCTAVE Nacional proporciona, como mínimo, cuatro beneficios:

1. Un autodiagnóstico estructurado de madurez en ciberseguridad, organizado en dominios claros (gobernanza, activos, riesgos, vulnerabilidades, incidentes, capacidades, cumplimiento, métricas).
2. La posibilidad de comparar su situación con organizaciones de tamaño y sector similares, sin necesidad de confesarse en público.
3. Un marco para conversar con la alta dirección en términos de riesgo, madurez y retorno de inversión, más allá del eterno “necesitamos más presupuesto”.
4. Una base para diseñar o revisar el plan de acción de ciberseguridad de los próximos años.

No prometemos milagros, pero sí **una radiografía útil** y una excusa razonable para hablar de ciberseguridad sin esperar al siguiente incidente grave.

5. Cómo utilizar los resultados internamente

Recomendamos que, una vez completada la encuesta:

- Se compartan los resultados con las personas clave (dirección, riesgos, continuidad, TI) y se discutan las áreas fuertes y débiles.
- Se prioricen 3–5 líneas de acción realistas, con plazos, responsables e indicadores asociados.
- Se aproveche el Índice Global de Madurez (IGM) para fijar metas de mejora razonables (por ejemplo, pasar de un nivel “medio” a “alto” en 24 meses en determinados dominios).
- Se utilice la plantilla de cálculo de ROI/ROSI para justificar inversiones clave.

La encuesta no solo pretende iluminar lo que falta, sino también reconocer lo que ya se hace bien. Conviene señalarlo: la ciberseguridad sostenible requiere tanto **humildad autocrítica** como **orgullo por los avances logrados**.

6. Sobre el tono de las preguntas y opciones de respuesta

Quizá observe que algunas opciones de respuesta están redactadas con **cierto tono irónico**, lejos del estilo completamente aséptico y burocrático.

No es un accidente.

La ironía medida ayuda a:

- Romper la resistencia inicial ante preguntas incómodas (“¿tenemos de verdad inventario de activos?”).
- Invitar a la honestidad (“nuestros activos críticos se identifican por el ruido que hacen al fallar” puede ser, desgraciadamente, una descripción certera).
- Facilitar que los equipos se reconozcan en las opciones y usen la encuesta como punto de partida para conversaciones francas.

En ningún caso la intención es ridiculizar a las organizaciones, sino **acompañar con humor** el esfuerzo muy serio de mejorar la seguridad.

7. Confidencialidad y uso responsable de los datos

Los resultados de la encuesta deben tratarse como información sensible:

- A nivel externo, solo se divulgarán resultados agregados por sector, tamaño u otros criterios, sin identificar organizaciones concretas salvo consentimiento explícito.
- A nivel interno, se recomienda compartir los resultados con todas las áreas implicadas, pero evitando su uso con fines punitivos individuales.
- Cualquier análisis de ROI/ROSI deberá subrayar las hipótesis utilizadas, para evitar falsas certezas.

La finalidad de todo el ejercicio es **mejorar la resiliencia**, no buscar culpables.

8. Mensaje final para la alta dirección

Si usted forma parte de la alta dirección o del órgano de gobierno y ha llegado hasta aquí, enhorabuena: ya es más de lo que puede decirse de muchos de sus colegas.

La Encuesta OCTAVE Nacional le ofrece una forma **estructurada, comparable y razonablemente sencilla** de responder a tres preguntas que ningún consejo de administración debería esquivar:

5. ¿Sabemos realmente qué activos digitales sostienen nuestro negocio y cuán expuestos están?
6. ¿Gestionamos el riesgo cibernético con el mismo rigor con el que gestionamos los riesgos financieros, legales o operativos?
7. ¿Podemos explicar —con algo más que fe— por qué nuestras inversiones en ciberseguridad son razonables y suficientes?

Si las respuestas no son todo lo sólidas que le gustaría, la buena noticia es que **está a tiempo de cambiarlo**. Esta encuesta no es el final del camino, pero sí un buen lugar para empezar a andar en la dirección correcta, con los ojos abiertos... y, de vez en cuando, una sonrisa.